Yatharth

Technical Design Document: lab report delivery portal for Company A, Vijayawada

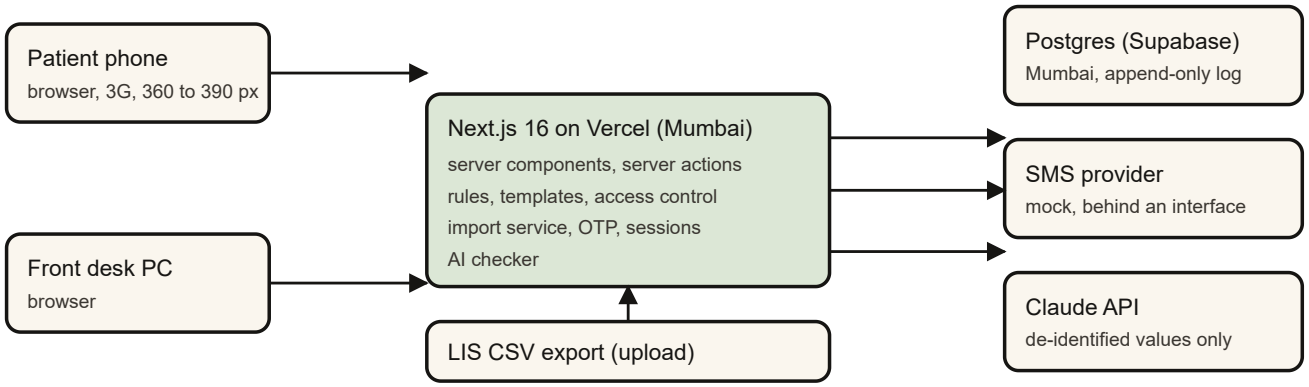
GitHub: https://github.com/shirii8/yatharth_Labs
Live app: not deployed yet
Demo logins: in deployment.md, section 3.
Built by shirii8, 4 to 9 November 2026. All patient data is synthetic. Version 8e0c8ac.

1. What was built

The core slice from the brief works end to end: an LIS CSV import, an automatic report link on sign-off, a patient portal with mobile number and OTP, a report view with a plain-language summary of out-of-range values, and a front-desk console that finds a patient, resends a link, shows delivery status and the access log. Two roles: patient and front-desk staff, plus a lab admin who approves wording and reviews the AI.

Brief, must have	Status
Patient login by mobile and OTP, orders with status, PDF download	Built. OTP with lockout, family on one number, status per report, PDF (a marked stand-in, A7).
Automatic SMS with an expiring link when a report is signed, fed by the LIS export	Built, with SMS mocked. Link created in the same transaction as sign-off; 72 hours; one report per link.
Plain-language summary of out-of-range values in English, Telugu and Hindi	Built. Rules plus locked templates; AI paragraph for tests without locked wording, checked before showing. Telugu approved from the design copy, Hindi waiting for approval to show the approval step.
Front-desk console: find a patient, resend links, delivery status, access log	Built, plus callbacks, flags, add a family member, wording approvals and the AI review.
Referring doctor view of the last 90 days	Not built (optional depth). The data model records the referring doctor on each report.
Delivery and access report for the operations head	Not built as a report. The data is all there: link delivery and opening times, and the access log.

2. Architecture and why



One Next.js app, server rendered. Patient pages are rendered on the server and ship little JavaScript, which suits old phones on 3G. UI and server logic share one language (TypeScript), which is the fastest way for one person to deliver a tested slice in a week. Django or Laravel with Postgres would also fit; Next.js was chosen for server rendering, one language end to end, and speed for a solo build.

Next.js 16, not 14. The plan said 14, but `npm audit` showed critical advisories on the 14 line with no fix. 16.4.5 has a clean production audit.

Structure. `lib/domain` holds pure rules (flags, critical limits, tokens, phone, OTP), each tested on its own. `lib/import`, `lib/auth`, `lib/summary`, `lib/ai`, `lib/patient`, `lib/staff` hold services that use the database. `app/` routes are thin. SMS and AI sit behind small interfaces (`SmsProvider`, `SummaryWriter`), so a real SMS gateway or an India-hosted model is one more class.

Hosting in India. The database is in Supabase's Mumbai region and Vercel functions are pinned to Mumbai (`bom1`). The AI receives no personal data (section 5).

3. Data model

17 tables in Prisma 7 (one schema file per group, one commit per group). Highlights:

Table	Holds	Design choice
Household	One mobile number	Stored as an HMAC for lookup, AES-256-GCM ciphertext for sending SMS, and a masked form for display. Consent version and time.
Patient	A family member	Unique by household and name: one number covers a family.
TestDefinition, Analyte	Tests and what they measure	Critical limits on the analyte; a locked flag for tests with approved wording.
Report, Result	One test on one order	Order plus test is unique (re-import is safe). Each result keeps the range printed on its report and the value as printed; the flag is computed by rule on write.
ReportLink	The SMS link	Only the token's hash is stored. Delivery, opening and revoke times.
OtpChallenge	One code	Hash only, attempts, lock. Not linked to a household, so unknown numbers look the same.

Table	Holds	Design choice
Session	A signed-in browser	Server-side, so it can be ended at once. Kinds: PATIENT, LINK (one report), STAFF.
AccessLog	Every opening and step	Append only: a database trigger refuses UPDATE, DELETE and TRUNCATE. Plain ids, no foreign keys, so it outlives what it describes.
CallbackTask, PatientFlag	Work for staff	A partial unique index allows one open critical call per report.
SummaryTemplate	Locked wording	Versioned per key and language, DRAFT or APPROVED, source human or AI.
AiSummary	Every AI attempt	Shown, refused or failed, with the checker's reason and the reviewer's verdict.
ImportBatch, ImportRow	Each LIS file and row	A sentence per bad row; the file's hash.

4. Main flows

4.1 LIS export to an SMS link

1. Staff upload the CSV (the export folder is simulated by upload, A4). Each row is validated; each problem becomes a sentence, for example "Phone number "900000001" is not a 10-digit Indian mobile number." Good rows import even when others are bad.
2. Rows of one order and test form a report. In one transaction: household, patient, report, results with rule flags, and, only when the report first becomes signed, a 72 hour link, a LINK_SENT log line and, for a critical result, a callback task due in 30 minutes.
3. After the transaction commits, the SMS is sent ("Lakshmi's Complete Blood Count report is ready. Open it here: ... The link works for 72 hours."). No result ever appears in an SMS. Delivery is recorded for the desk.
4. Uploading the same file again changes nothing; a later "Processing" row can never unsign a report.

4.2 Opening a link

The link page only checks the token. Opening the report needs a tap, because message apps fetch links to draw previews. The tap opens a session for that one report, capped at 2 hours and never past the link's 72 hours, and logs LINK_OPENED. Consent comes first. An expired or revoked link shows "We tied this page up for you" and offers a code.

4.3 Signing in with a code

Mobile number, then a six-digit code that lasts 10 minutes. Five wrong codes pause the number for 15 minutes; a resend waits 60 seconds; at most 5 codes a day (A19). An unknown number gets the same screens but no SMS. Codes are stored as keyed hashes and compared in constant time. Signing in opens the whole family's file, including pages whose links expired (A28).

4.4 Reading a report

Every report read joins through the session's own household, so an ID typed into the URL can never reach another family (tested). The opening is logged in the same transaction as the link's open count. Simple mode shows one result at a time with a ruler; Compact shows all results and the trend since the last report.

4.5 Critical values

The patient sees no number, no summary and no flag words: "Please call us about your report", with the first step already ticked ("We have asked our team to call you", with the time). The callback task was created with the report's link. Staff see the value and range on the desk. The AI is never involved.

4.6 Front desk

Search by full number (matched by hash), last four digits or name. Opening a record is logged; the full number is shown only on request, and that is logged too. Resend revokes the old link at once and sends a new one. Calls are marked done with a note; flags are resolved with a note.

5. How the AI part works, and what happens when it is wrong

Rules decide every flag. Locked templates supply every sentence. The AI writes only the short "In short" paragraph, and only for tests without locked wording, and only if a checker passes it.

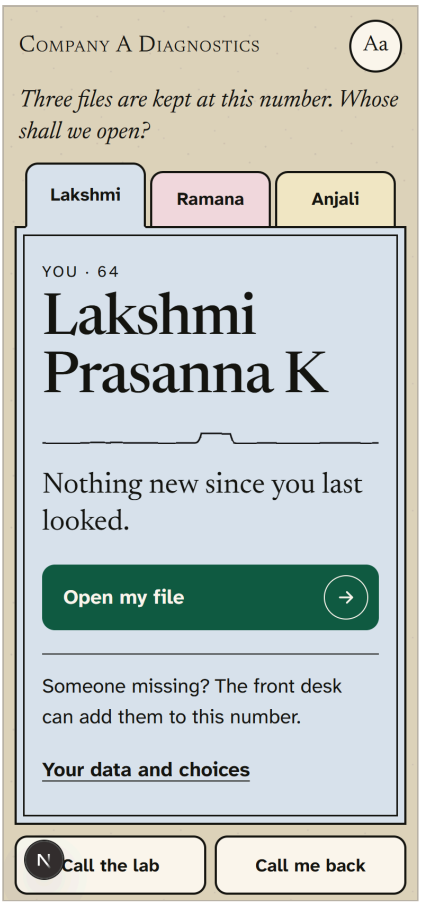
1. **Rules** set LOW, USUAL or HIGH against the range printed on the report, and "mild" or "marked" by how far past the limit (more than 20% is marked: 10.2 against 12.0 is "a little low").
2. **Templates** turn each finding into words. A test fails if any sentence the builder produces does not match an approved template.
3. **Critical reports** get no summary and no AI call.
4. **Locked tests** (the brief's top 30; CBC and Electrolytes in the demo) use templates only.
5. **Other tests** (Lipid, Thyroid in the demo) get an AI paragraph from claude-opus-5-5 at low effort. The model receives only test name, analyte names, values, units, printed ranges and the rule's words. No name, phone, age or order ID.
6. **The checker** refuses any number not on the report, disease or organ names, medicine or treatment advice, alarming or falsely calming words, a flag that disagrees with the rule, or a flagged result left out.
7. **When the AI is wrong or unsure:** a refused answer, an error, or no answer within 8 seconds means the patient sees the template sentence instead, at once. Every attempt is stored with the reason.
8. **Human review:** the lab admin's review page shows unreviewed summaries next to the rule findings, counting toward the brief's 50 a week. Marking one "wrong" stops it showing immediately. Patients can also press "Something looks wrong".
9. **Translations:** the AI can draft Telugu or Hindi wording for any approved English template. Drafts keep every placeholder or are dropped, and stay hidden until a lab admin approves them; until then the patient sees English.

6. UI and design decisions

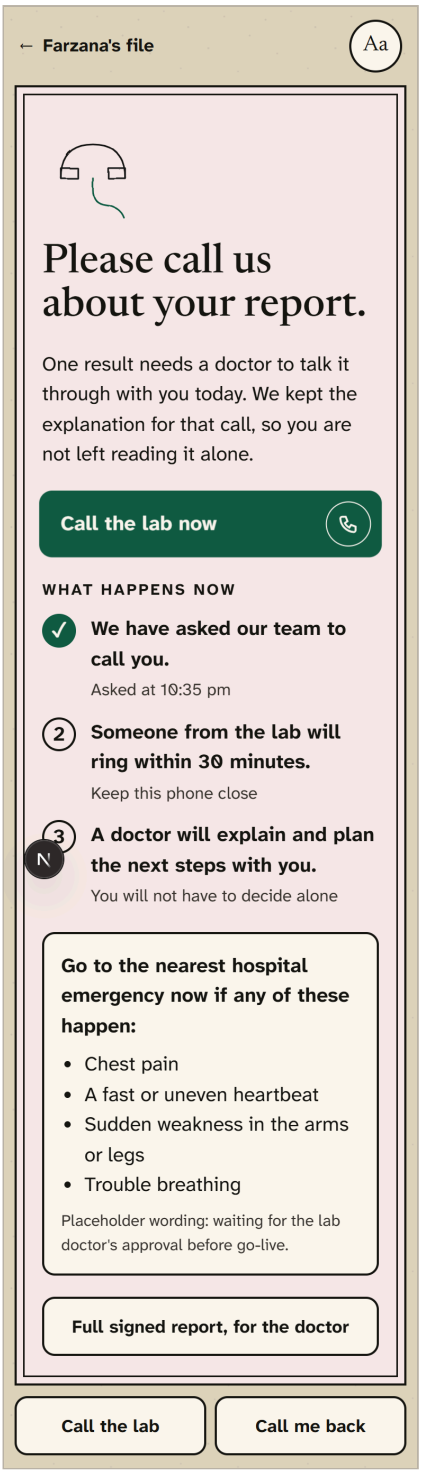
The design idea is "your health file, kept by people who know you": every report is a page in a file, behind an index tab. The client values minimal, purposeful design, and many patients are elderly on small phones, so every screen has one large serif line, one green next step, large type (19 px, 22 px with Aa), and plain, calm words. Status is always a word plus a mark, never colour alone. There is no red anywhere a patient looks.



Sign in: language tabs, one field, one green button. The demo hint shows only in demo mode.



Whose file: one tab per person on the number; the tab's colour carries into the page.



Please call us: no value, no summary, the call already queued, a fixed safety note.

← Lakshmi's file

Compact

Aa

Lakshmi garu,

your Complete Blood Count report is here.

Of 3 results, 2 are in the usual range. Haemoglobin is a little low.

Read it aloud to me

1 | 2 | 3

RESULT 1 OF 3

Haemoglobin

Carries oxygen around your body.

10.2 g/dL

usual 12.0–15.5

You

A little low. Your doctor will tell you whether anything needs to be done.

Marked by the lab's rule: below 12.0, the lower end of the range printed on your signed report.

Next result

WHAT TO DO NEXT

1 Show this page to your doctor at your next visit. No need to rush.

2 Very tired or short of breath? Call your doctor sooner.

3 Questions? Tap "Call me back" and one of us will ring you.

Printable copy | Full signed report

Something looks wrong? Tell us

Written in your file: opened 5 Nov, 12:47 am.
Every opening

These words come from the lab's checked wording for this test. Low and usual come from the ranges printed on your signed report. Your doctor's advice comes first.

Call the lab | Call me back

← Lakshmi's file

Simple

Aa

Lakshmi garu,

your Complete Blood Count report is here.

Of 3 results, 2 are in the usual range. Haemoglobin is a little low.

Read it aloud to me

ALL RESULTS

Haemoglobin 10.2 g/dL

▼ A little low. usual 12.0–15.5

You

White blood cells 7.1 x10^3/uL

✓ In the usual range. usual 4.0–11.0

You

Platelets 262 x10^3/uL

✓ In the usual range. usual 150–410

You

Checked by the lab's rule against the range printed on your signed report.

SINCE LAST TIME

12 Aug — Now

Haemoglobin was 10.9 on 12 Aug. This time it is 10.2.

WHAT TO DO NEXT

1 Show this page to your doctor at your next visit. No need to rush.

2 Very tired or short of breath? Call your doctor sooner.

3 Questions? Tap "Call me back" and one of us will ring you.

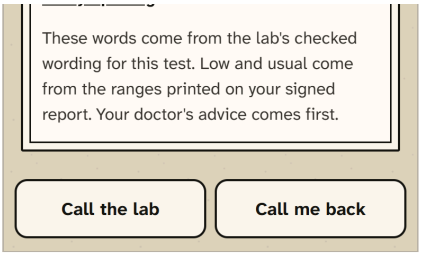
Printable copy | Full signed report

Something looks wrong? Tell us

Written in your file: opened 5 Nov, 12:47 am.
Every opening



Desk: critical calls first, each closed with a note.



Report, Simple: one result at a time; the ruler's position comes only from the printed range.

Report, Compact: all results and the trend since last time, drawn as a small inline SVG.

Decision	Why
Tabs, Back and Next are plain links; forms are plain posts	Everything works before JavaScript loads on a slow phone.
Fonts self-hosted and split by script (unicode-range)	No call to Google Fonts; a phone downloads Telugu glyphs only when a page shows Telugu.
Telugu and Hindi get taller line height and a smaller display size	The scripts are taller; buttons grow and never clip (checked at 390 px).
Three motion moments only (opening a report, the value finding its place, please call us), transform and opacity only	Calm, cheap on old phones, and shown as a final frame under reduced motion.
Listen uses the phone's own voice	Nothing leaves the phone; the button hides when there is no voice.
One notice layout for expired, invalid, timeout, loading, empty, error, withdrawn	Every dead end says what happened and what to do next, signed by the front desk.

7. Security and privacy (DPDP Act 2023)

- **Consent** once, before any report, stored with its text version and time; withdrawing ends every session on the number, stops links and SMS, and is logged. A critical result still creates a staff call.
- **Access log** for every code sent, sign-in, link and report opening, PDF download, consent change, staff view and full-number view, written in the same transaction as the action. The database refuses to change or delete it. Patients read their own record in plain words.
- **Secrets** only in environment variables; `.gitignore` was the first commit. Phone numbers hashed and encrypted; tokens and codes stored only as keyed hashes.
- **Access control** on the server for every page and action: reports through the session's household (IDOR tests), link sessions scoped to one report, staff roles per route (tested so no desk route lacks a permission).
- **Abuse limits:** OTP lockout, cooldown and daily cap; staff lockout after 5 wrong passwords; same answers for unknown numbers and emails.
- **Inputs** validated with Zod at every boundary; errors are sentences.
- **Headers:** Referrer-Policy no-referrer (links carry tokens), framing refused, nosniff, HSTS in production, private pages never cached.

8. Testing

Kind	Count	What it proves
Unit (Vitest)	93	Flags and boundaries, critical limits, 72 hour links, phone rules, OTP limits, CSV reading and row errors, summary builder (no free text), AI checker, staff permissions.
Database (Vitest, real Postgres)	57	Idempotent import with the brief's three orders, links on sign-off, critical calls, OTP sign-in and lockout, IDOR and consent rules, link sessions, call-backs and flags, resend, staff lockout, AI summary paths with fake writers, append-only log.
End to end (Playwright)	4	Sign in to a report explained by rule; a critical page with no value; five wrong codes pause the number; a staff import listing bad rows.

Logic was written test first, visibly in the git history (a `test:` commit, then a `feat:` commit).

9. Performance and accessibility

First load measured on the production build at 390 px: about 155 KB transferred per page without fonts, of which about 135 KB is the React and Next.js runtime and about 20 KB is this app's code and CSS. This misses the 150 KB budget by about 5 KB; the next step is to drop the remaining client components from pages that do not need them. Fonts are a one-time, cached download. Every screen has a loading, empty and error state. Accessibility: real buttons, links and labels; each code box labelled; the ruler is one image with a full-sentence label; 3 px green focus ring; body text contrast above 7:1; touch targets at least 48 px.

10. Assumptions

Everything the brief does not say and the build had to decide, as kept in `docs/ASSUMPTIONS.md`:

Client and scope

- A1. The client is the lab chain in Vijayawada described in the brief. An earlier build plan said Navi Mumbai; that was an error and the brief wins.
- A2. Roles built in the core slice are patient and front-desk staff, as the brief asks. A `lab_admin` role is added only to approve wording (templates and translations), because front-desk staff should not change medical wording.
- A3. Referring doctor view and the operations delivery report are optional depth. They are built only if the core slice is finished.

Lab system and delivery

- A4. The LIS export folder is simulated by uploading its CSV in the staff console. The import service takes a file, so a folder watcher can call the same code later. No change to the LIS, which is out of scope.
- A5. A report counts as signed when its export row says `Ready` or `Ready (critical)`. `Processing` means tested but not signed, and is never shown to the patient as a result.
- A6. Messages go out as SMS through a mock provider. WhatsApp, which the brief also allows, would be a second implementation of the same interface.
- A7. The signed PDF comes from the LIS and is not in the sample data, so the demo serves a generated stand-in clearly marked as a sample.

Links and sign-in

- A8. Read literally, the brief says a link opens its one report for 72 hours, and after that the patient signs in with an OTP to reopen it. The build follows that reading.

Data and hosting

- A9. "Hosting in India" is met with the database in Supabase's Mumbai region and Vercel functions pinned to the Mumbai region.
- A10. Seed data uses the brief's sample patients, orders and results. Phone numbers are fake (+91 90000 0000x), and extra family members are invented.

AI summaries

- A11. The AI makes real model calls; it is a required feature, not a mock. Rules decide every flag. The AI only writes the wording, and a checker rejects any output whose numbers or flag words do not match the rules, or that uses banned words. On a rejected output, a timeout or no API key, the patient sees the plain rule line and the full report link.
- A12. The AI receives only the test name, analyte names, values, units, ranges and rule flags. No name, phone, age or order ID is sent, so no personal data leaves India. An India-hosted model (for example Sarvam) can replace it behind the same interface.
- A13. Critical results never reach the AI. Tests with an approved locked template use the template text and make no AI call at read time.
- A14. Telugu and Hindi wording written by the AI is a draft until a lab_admin approves it. Until then the patient sees English.

- A22. The AI model is claude-opus-5-5 at low effort, set by AI_MODEL. It gets one try with an 8 second limit and no retries; after a failed or refused attempt it is not asked again for that report for 24 hours, and the patient sees the rule-based wording.

Import format and test catalog

- A15. The LIS export has the brief's sample columns (Order ID, Patient, Parameter, Result, Reference Range, Status, Referring Doctor) plus Phone, Age, Sex, Test Code, and optional Relation and Signed At. The brief does not give the full layout, and a patient cannot be reached without a phone number.
- A16. A patient is matched by phone number plus name. A new name on a known number becomes a new family member on that number.
- A17. Critical limits (for example potassium 6.0 mmol/L and above, haemoglobin 7.0 g/dL and below) are placeholders. The brief gives none, so the lab doctor must confirm them before go-live. A report is also critical whenever the LIS marks it "Ready (critical)".
- A18. CBC and Electrolytes have locked, doctor-approved templates in the demo; Lipid and Thyroid do not, so the demo shows both the template path and the AI path.

Sign-in and sessions

- A19. The brief asks for a daily cap on codes but gives no number. The cap is 5 codes per number in 24 hours.
- A20. A patient session ends after 30 minutes without use and after 12 hours at most. A session opened from an SMS link lasts at most 2 hours and opens only that report. Staff sessions end after 2 hours idle or 10 hours.
- A21. Three demo numbers (+91 90000 00001 to 00003) accept a fixed code only when DEMO_MODE is on, so reviewers can sign in without a phone. It is off by default.
- A23. In demo mode only, the three demo numbers skip the 60 second resend wait and the daily cap, because their code is fixed and no SMS is sent; many reviewers may sign in on the same day. The five-wrong-tries pause still applies.

Staff work and patient requests

- A24. The staff desk is in English only. Telugu and Hindi are for patients.
- A25. The brief gives no call times. A critical result asks staff to call within 30 minutes; "Call me back" within 2 hours, between 8 am and 8 pm.
- A26. "Call me back" needs a sign-in or an open link, so the lab knows whose file it is. Signed out, the page offers the lab's phone number instead of promising a call.
- A27. "Something looks wrong" creates a flag for staff. Nothing on the report changes until a doctor has looked.
- A28. Signing in with a code opens every signed report on that number, including ones whose SMS link has expired. The code is the "OTP to reopen" the brief asks for.

11. What was cut, honest limits, and what comes next

- **Cut:** the referring doctor view and the operations report (optional depth); a doctor role.
- **Mocked by design:** SMS (provider interface ready for an SMS or WhatsApp gateway) and the signed PDF (a marked stand-in).

- **Limits:** Telugu and Hindi copy comes from the design and needs native review; critical limits and the safety note are placeholders for the lab doctor; correcting a phone number on file is not built; there is no folder watcher yet (the import service is ready for one); the page-weight budget is missed by about 5 KB.
- **Next:** a real SMS gateway with delivery receipts; the referring doctor view (90 days, by doctor); an operations dashboard from the delivery and access data; an India-hosted model behind the same interface; native-speaker review and doctor sign-off of all wording; a folder watcher for the LIS export.